Seguridad y Alta Disponibilidad · UD1
Ejercicios: Amenazas físicas y lógicas

Objetivo
Analizar amenazas reales que pueden afectar a un sistema informático, diferenciando amenazas físicas y lógicas, identificando vulnerabilidades, impacto y medidas de protección.

Conceptos de referencia
Amenaza física: afecta a elementos tangibles como hardware, instalaciones o infraestructura.

Amenaza lógica: afecta a elementos intangibles como software, datos, credenciales o procesos.

Una misma amenaza puede afectar a varias propiedades de seguridad:
- Confidencialidad: evitar accesos no autorizados.
- Integridad: evitar modificaciones incorrectas.
- Disponibilidad: garantizar que los servicios funcionen cuando se necesitan.

Ejercicio 1 — Clasifica la amenaza
Para cada situación indica:
1. Si es una amenaza física, lógica o ambas.
2. Qué elemento vulnerable afecta.
3. Qué propiedad de seguridad se ve comprometida.
4. Una medida preventiva.

Caso 1:
Un incendio destruye el servidor donde se aloja la aplicación de gestión del centro.

-Tipo de amenaza: Física.

-Elemento vulnerable: Servidor e instalaciones donde se encuentra.

-Propiedad comprometida: Disponibilidad, porque el servidor deja de funcionar y la aplicación no puede utilizarse.

-Medida preventiva: Instalar sistemas de detección y extinción de incendios y disponer de copias de seguridad.

Caso 2:
Un empleado utiliza una contraseña sencilla que acaba siendo descubierta mediante un ataque.

-Tipo de amenaza: Lógica.

-Elemento vulnerable: Cuenta de usuario y credenciales de acceso.

-Propiedad comprometida: Confidencialidad, porque una persona no autorizada puede acceder a la cuenta y a la información.

-Medida preventiva: Utilizar contraseñas fuertes y activar la autenticación multifactor (MFA).

Caso 3:
Una subida de tensión provoca daños en varios equipos de red.

-Tipo de amenaza: Física.

-Elemento vulnerable: Equipos de red e infraestructura eléctrica.

-Propiedad comprometida: Disponibilidad, porque los equipos dañados pueden dejar de proporcionar conexión a la red.

-Medida preventiva: Utilizar sistemas de alimentación ininterrumpida (SAI/UPS) y protectores contra sobretensiones.

Caso 4:
Un ransomware cifra los documentos compartidos de una empresa.

-Tipo de amenaza: Lógica.

-Elemento vulnerable: Archivos, datos y sistemas de almacenamiento.

-Propiedad comprometida: Disponibilidad e integridad, ya que los usuarios no pueden acceder normalmente a los archivos y estos han sido modificados mediante el cifrado.

-Medida preventiva: Mantener copias de seguridad periódicas y actualizadas, además de utilizar antivirus y sistemas de protección contra ransomware.

Caso 5:
Un atacante aprovecha una vulnerabilidad del sistema operativo para instalar software malicioso.

-Tipo de amenaza: Lógica.

-Elemento vulnerable: Sistema operativo y software instalado.

-Propiedad comprometida: Confidencialidad e integridad, porque el atacante puede acceder a información y modificar el sistema.

-Medida preventiva: Mantener el sistema operativo actualizado y aplicar los parches de seguridad.

Caso 6:
Una persona accede físicamente a una sala de servidores y conecta un dispositivo desconocido a la red.
-Tipo de amenaza: Ambas, física y lógica.
-Elemento vulnerable: Sala de servidores, equipos de red y dispositivos conectados.

-Propiedad comprometida: Confidencialidad e integridad, porque el dispositivo podría permitir acceder a información o modificar sistemas.

-Medida preventiva: Controlar el acceso físico a la sala de servidores mediante cerraduras, tarjetas o sistemas de identificación y controlar los dispositivos conectados a la red.

Ejercicio 2 — Análisis de incidente de seguridad

Una pequeña empresa tiene todos sus servicios en un único servidor físico situado en una habitación sin climatización, sin control de acceso y sin copias de seguridad externas.

Después de una tormenta eléctrica, el servidor deja de funcionar y la empresa pierde varios documentos importantes.

Responde:
- ¿Qué amenazas aparecen en el caso?

Aparece principalmente una tormenta eléctrica que provoca el fallo del servidor. También existe riesgo de sobrecalentamiento por no disponer de climatización y de acceso no autorizado debido a la falta de control de acceso.

- ¿Son físicas, lógicas o ambas?

Son principalmente amenazas físicas, ya que afectan al servidor y a las instalaciones. Además, la pérdida de documentos afecta a los datos, por lo que también puede tener consecuencias sobre la seguridad lógica.

- ¿Qué vulnerabilidades han permitido el incidente?

Las principales vulnerabilidades son tener todos los servicios en un único servidor físico, no disponer de climatización, no tener control de acceso y, especialmente, no disponer de copias de seguridad externas.

- ¿Qué medidas aplicarías para reducir el riesgo?

Instalaría un SAI/UPS y protectores contra sobretensiones, sistemas de climatización adecuados y control de acceso a la sala. También realizaría copias de seguridad periódicas y externas y, si es posible, utilizaría servidores redundantes para evitar depender de un único equipo.

- ¿Qué propiedad de seguridad queda más afectada? Justifica la respuesta.

La propiedad más afectada es la disponibilidad, porque el servidor deja de funcionar y los servicios de la empresa quedan interrumpidos. También se ve afectada la integridad, ya que se han perdido documentos importantes.

Ejercicio 3 — Ingeniería social

Un trabajador recibe un correo aparentemente enviado por el departamento de informática. Le solicitan introducir sus credenciales en una página web para "actualizar la seguridad de su cuenta".

Después de introducirlas, un atacante utiliza la cuenta para acceder a documentos internos.

Analiza:
- Tipo de amenaza.

Es una amenaza lógica, ya que busca obtener credenciales para acceder a sistemas y documentos de la empresa.

- Técnica utilizada.

Se utiliza phishing, concretamente un correo fraudulento que suplanta al departamento de informática para engañar al trabajador y obtener sus credenciales.

- Propiedades de seguridad afectadas.

Principalmente la confidencialidad, porque el atacante consigue acceder a documentos internos. También puede verse afectada la integridad si el atacante modifica o elimina información.

- Indicadores que podrían haber alertado al trabajador.

-El remitente del correo podría no pertenecer realmente a la empresa.

-El mensaje podría contener errores ortográficos o un lenguaje poco habitual.

-El enlace podría dirigir a una página con una dirección web sospechosa.

-Se solicitan las credenciales mediante un enlace recibido por correo.

-El mensaje puede crear sensación de urgencia para que el trabajador actúe rápidamente.

- Medidas preventivas que debería aplicar la organización.

La empresa debería realizar formación sobre phishing e ingeniería social, utilizar autenticación multifactor (MFA), disponer de filtros antispam y sistemas de detección de correos fraudulentos y establecer procedimientos para verificar cualquier solicitud de credenciales. Además, debería aplicar el principio de mínimo privilegio para limitar el acceso de cada usuario únicamente a la información que necesita.